



BSOS

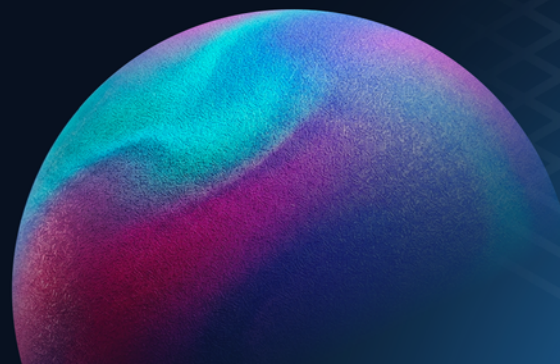
智能合約安全檢測報告

檢測工具

Slither

檢測日期

2026-08-14 ~ 2026-08-14



目錄

- 摘要
- 掃描範圍
- 協定理解摘要
- 檢測方法
- 掃描環境資訊
- 情境庫覆蓋
- 待處理項目
- 發現明細
- 已評估項目摘要
- 附錄：發現處置分類

摘要

受檢對象：（測試夾具）

檢測期間：2026-08-14 ~ 2026-08-14

受檢版本：4eeef1e077b74137cc280cec07123b9a7a2a1ad0

本次共提出 6 項發現（掃描工具產出 5 項、人工複核產出 1 項），依嚴重程度分布如下：

嚴重程度	筆數
Critical	0
High	0
Medium	0
Low	4
Informational	2
總計	6

需要決策或行動的項目彙整於「待處理項目」，逐筆說明見「發現明細」。

掃描範圍

本次檢測涵蓋以下 1 個 Solidity 原始檔（合計 84 行）。此清單即本報告的效力邊界——未列於此的檔案不在本次檢測範圍內。

檔案	行數
src/TimelockVault.sol	84

檔案內容雜湊（SHA-256），供比對交付程式碼是否與受檢版本一致：

src/TimelockVault.sol — 92b31524c7baf9e16ae14fe053dc4fd6bc3d26687eec07920493b059f839849d

協定理解摘要

本受檢對象為迴歸測試夾具，不是要交付的產品合約：TimelockVault 是為驗證本工具判級邏輯而刻意設計的最小化定存型金庫，預期結果事先寫死（見 FIXTURE_NOTES.md）。此節的內容僅供版面驗證之用。

合約職責

合約	職責
TimelockVault.sol	接受 ETH 存入並鎖倉 7 天；到期後可提領，提領時收取手續費並累計於合約內

資產與托管

使用者存入的 ETH 全部停在 TimelockVault 自身；balances 記錄各地址可提領餘額，accruedFees 記錄尚未被提走的手續費。

特權角色權限表

角色	可呼叫	後果
owner（建構時設定，immutable）	sweepFees(address to)	把 accruedFees 全額轉往指定地址。不能動使用者的 balances。

檢測方法

本次檢測依以下步驟執行：

1. **建置與環境確認**：確認專案可完整編譯，記錄工具鏈與相依套件版本（見「掃描環境資訊」）。

2. **靜態分析掃描**：以 Slither 對「掃描範圍」所列全部原始檔執行完整 detector 掃描。

3.

逐筆人工分類複核：對掃描產出的每一筆發現判定其處置分類（A／B／C／D）並記錄判斷依據；工具回報的嚴重度與本報告呈現的嚴重度若有落差，逐筆附上調整理由。

4.

情境式邏輯漏洞比對：對範圍內每一份合約，逐條比對內部維護的邏輯漏洞情境庫（權限檢查實作、未保護的狀態變更、旗標未落實、價格源可操縱、記帳與實際結果脫鉤、簽章雜湊綁定範圍、可組合模組的交互失效等），補靜態分析無法涵蓋的業務邏輯層級問題。逐合約的比對結果見「情境庫覆蓋」。

5.

領域事故模式比對：依受檢系統所屬業務領域，比對該領域公開已知的事故模式，檢查應具備而未實作的機制。

6. **產出與覆核**：彙整為本報告，並對共用同一判斷理由的發現群組進行抽查。

範圍限制

- 靜態分析擅長偵測「程式寫法特徵層級」的問題（重入模式、tx.origin 授權、弱亂數來源、未檢查的低階呼叫回傳值等）；業務邏輯層級的問題不在其可偵測範圍內，由上述第 4、5 步以人工方式補足，但人工複核的覆蓋程度不等同於系統性審計。
- 本報告為交付前之**自我檢查證明**，證明工程團隊已執行掃描並對每一筆發現完成逐筆判讀；其不構成、亦不取代由獨立第三方執行之完整安全審計。

掃描環境資訊

項目	內容
掃描時間	2026-07-14T12:42:40.677595
專案路徑	/home/kai/security-scan-kit/test-fixtures/timelock-vault
Git commit	4eeef1e077b74137cc280cec07123b9a7a2a1ad0
Solidity / solc 版本	unknown
Slither 版本	0.11.5
Foundry (forge) 版本	forge Version: 1.3.5-stable

情境庫覆蓋

下表為情境庫逐合約的比對結果。「已查證」為前置條件成立、實際讀碼確認過的情境數；「不適用」為合約不具備該情境前置條件而跳過的情境數；「命中」列出對應的發現編號。

合約	已查證	不適用	命中
src/TimelockVault.sol	8	11	TLV-06

待處理項目

本次無需要決策或處理的項目。

發現明細

以下逐筆列出 1 項發現。低嚴重度且已判定為可接受風險或誤報的項目不在此節，彙整於「已評估項目摘要」。

TLV-06 | deposit() 每次加碼會重置整筆餘額的鎖倉期

嚴重度	Low
處置	已知風險但可接受 (B)
位置	src/TimelockVault.sol:38-43

說明：unlockAt[msg.sender] 在每次 deposit() 時整筆覆寫為 block.timestamp + LOCK_PERIOD (L41)，代表使用者加碼 1 wei 就會把既有全部餘額重新鎖 7 天。若前端或第三方合約代使用者存入，可能造成非預期的延長鎖倉。

判斷依據：與產品方確認過這是刻意設計（「任何異動重新起算定存期」），且已寫入使用者文件；技術上若要改為分批鎖倉需要 per-deposit 的紀錄結構，成本與收益不成比例。評估為可接受風險，於文件揭露。

已評估項目摘要

以下 5 項為低嚴重度（Low／Informational）且經判定為可接受風險（B）或誤報（C）的發現，依檢查器與判定理由歸併為 5 組。逐筆明細保留於工作底稿，可依需要調閱。

檢查器	筆數	處置	判定理由
reentrancy-events	1	誤報（C）	withdraw() 遵循 checks-effects-interactions：balances[msg.sender] 與 accruedFees 皆在外部呼叫前完成更新（L...
reentrancy-events	1	誤報（C）	sweepFees() 同樣先把 accruedFees 歸零（L70）才做外部呼叫，且有 onlyOwner 保護（已檢查 modifier 實作：require(msg.sen...
timestamp	1	已知風險但可接受（B）	鎖倉判斷確實依賴 block.timestamp，出塊者可在共識容忍範圍內（秒級）微調時間戳，理論上能讓提款提早數秒解鎖。但 LOCK_PERIOD 為 7 天，秒級誤差對業務無實...
low-level-calls	1	誤報（C）	刻意選用 call{value;} 而非 transfer/send：後兩者的 2300 gas 上限在收款方是合約（多簽、智能錢包）時會失敗，call 是 Istanbul 之後...
low-level-calls	1	誤報（C）	同 #4：call{value;} 為建議寫法（國庫地址可能是多簽合約），回傳值有 require(ok) 檢查。

附錄：發現處置分類

本報告對每一筆發現標示兩個獨立欄位：**嚴重度**（Critical／High／Medium／Low／Informational，由工程團隊依實際影響判定）與**處置**（下列 A／B／C／D）。掃描工具自身回報的 impact 若與本報告呈現的嚴重度不同，該筆會並列印出兩者與調整理由。

- **A | 已確認需修復**：確認為真實問題（多涉及資金流向或權限控制邏輯），必須修復。
- **B | 已知風險但可接受**：問題確實存在，但經工程團隊評估風險可控（例如僅管理者可呼叫、另有其他層級防護），附具體理由後接受並於報告揭露。
- **C | 誤報**：靜態分析限制造成的誤判，實際已有防護機制或該判斷邏輯不適用。
- **D | 待確認**：尚無法判定歸屬者一律列此類；判讀信心不足時寧列 D，不猜測分類。此類項目均附「要確認什麼／由誰確認／兩種答案各自的處置」。
- 人工複核發現僅得分類 A／B／D；經確認非問題者直接自清單移除，不設誤報分類。